

HTB Academy — Quy trình kiểm thử xâm nhập

Tổng quan mô-đun

Mô-đun: Penetration [LAB_PASSWORD_REDACTED] Process

Bản dịch: Quy trình kiểm thử xâm nhập

Trình độ: Cơ bản

Tier: 1

Thời gian dự kiến: 6 giờ

Tổng số phần: 15

Bài tập tương tác: 4

Mô tả

Mô-đun dạy quy trình pentest, chia và thảo luận chi tiết từng giai đoạn. Nội dung đề cập nhiều khía cạnh vai trò pentester qua ví dụ thực tế, cùng bước trước dự án như phạm vi, hợp đồng, quy tắc.

Tóm tắt

Giải thích toàn quy trình chi tiết, nhấn mạnh thành phần thiết yếu bằng ví dụ. Pentest có thể tác động hệ thống nên cần chuẩn bị đội thực hiện và khách hàng: hợp đồng, phạm vi, tổ chức, thu thông tin, xác minh kỹ thuật, chứng minh khái niệm, báo cáo, khắc phục, kết thúc đúng cách.

Cấu trúc

- Sử dụng Academy hiệu quả
 - Giới thiệu lộ trình pentester
 - Cấu trúc mô-đun Academy
 - Bài tập, câu hỏi Academy
- Nền tảng và chuẩn bị
 - Tổng quan pentest
 - Luật, quy định
 - Quy trình pentest
- Giai đoạn pentest — Các bước đánh giá
 - Trước dự án
 - Thu thập thông tin
 - Đánh giá lỗ hổng
 - Khai thác
 - Sau khai thác
 - Di chuyển ngang
- Giai đoạn pentest — Kết thúc dự án
 - Chứng minh khái niệm

- Sau dự án

5. Chuẩn bị pentest thực tế

- Thực hành

Sơ đồ tư duy mô-đun

Ý tưởng trung tâm: **Pentest là quy trình thích nghi, lặp và dựa trên bằng chứng.**

Luồng tổng thể HTB:

Trước dự án → Thu thông tin → Đánh giá lỗ hổng → Khai thác → Sau khai thác → Di chuyển ngang → Chứng minh khái niệm → Sau dự án

Không tuyến tính, cứng nhắc. Thực tế pentester thường:

- quay lại thu thông tin;
- đánh giá lại phát hiện;
- chỉnh giả thuyết;
- đổi hướng tấn công;
- cập nhật ghi chép tác động;
- kiểm thử lại sửa lỗi;
- thích nghi phương pháp với môi trường khách hàng.

Phần 1 — Introduction to the Penetration [LAB_PASSWORD_REDACTED] Path

Dịch tiêu đề

Giới thiệu lộ trình pentester

Nội dung cốt lõi

Giới thiệu **Penetration [LAB_PASSWORD_REDACTED] Job Role Path** là lộ trình chính HTB Academy đào tạo pentester có nền tảng kỹ thuật, góc nhìn quy trình, kinh nghiệm thực tế. Người học nên quay lại mô-đun này trong suốt lộ trình để hiểu từng chủ đề nằm ở đâu trong công việc tổng thể.

Lộ trình dành cho:

- người mới muốn vào bảo mật tấn công;
- chuyên gia có kinh nghiệm muốn đào sâu, hoàn thiện hoặc học từ góc nhìn khác.

Khái niệm chính phục vụ:

- pentest bên ngoài;
- pentest mạng nội bộ, Active Directory;
- đánh giá bảo mật web.

Trọng tâm không chỉ công cụ mà là:

- kỹ thuật;
- phương pháp;
- bối cảnh;
- tư duy;

- “vì sao” phía sau lỗi, chiến thuật.

Triết lý học HTB

Học qua làm. Dạy người học:

- thấy hai phía vấn đề;
- tìm lỗi người khác bỏ qua;
- xây phương pháp riêng, lặp lại được, sâu sắc;
- sử dụng kỹ năng hợp pháp, có đạo đức;
- hiểu lỗ hổng, khai thác, sửa, phát hiện, ngăn ngừa là cùng chu trình.

Nhiều bài thực hành, lặp có cấu trúc nhằm tạo phản xạ nghề nghiệp (“muscle memory”).

Đạo đức, pháp lý

Bảo mật tấn công chỉ hợp lệ khi:

- có ủy quyền;
- có phạm vi;
- có kiểm soát;
- có môi trường phù hợp.

Phân biệt lab an toàn với tấn công trái phép mục tiêu thật. Nhấn mạnh:

- hợp đồng, phạm vi bằng văn bản;
- nguyên tắc **không gây hại**;
- ghi lại mọi thứ;
- luôn trong giới hạn pháp lý, đạo đức.

Chương trình lộ trình

- nhập môn;
- trinh sát, liệt kê, lập kế hoạch tấn công;
- khai thác, di chuyển ngang;
- khai thác web;
- sau khai thác;
- báo cáo, bài tổng kết.

Bài học chính

- Dạy **quy trình**, không chỉ công cụ.
- Dùng mô-đun làm tham chiếu suốt lộ trình.
- Cần nền tảng rộng về CNTT, bảo mật, hệ thống, mạng, web.
- Đạo đức, pháp lý, ghi chép thuộc nghề ngay từ đầu.

Phần 2 — Academy Modules Layout

Dịch tiêu đề

Cấu trúc mô-đun Academy

Nội dung cốt lõi

Nền tảng chính HTB ban đầu là CTF, máy thử thách mang tính cạnh tranh; còn thiếu hệ sinh thái hướng dẫn người mới và tiến bộ có cấu trúc. Academy ra đời lấp khoảng trống đó.

Pentester không thể chỉ dùng công cụ. Để tự tin cần hiểu sâu:

- Linux;
- Windows;
- mạng;
- web;
- viết script;
- cơ sở dữ liệu;
- Active Directory.

Lý thuyết thiếu thực hành chưa đủ

HTB so học tấn công với học nhạc cụ: biết lý thuyết không đồng nghĩa biểu diễn tốt.

- biết khái niệm không thực hành chưa tạo sự trưởng thành vận hành;
- thiếu thực hành không phát triển phản xạ kỹ thuật, phân tích thực tế.

Tổ chức theo giai đoạn pentest

- Trước dự án
- Thu thông tin
- Đánh giá lỗ hổng
- Khai thác
- Sau khai thác
- Di chuyển ngang
- Chứng minh khái niệm
- Sau dự án

Mỗi giai đoạn có mô-đun được khuyến nghị. Thứ tự theo logic dự án thật, không ngẫu nhiên.

Tính lặp

Pentester có thể:

- thu thông tin;
- đánh giá lỗ hổng;
- khai thác;
- quay lại thu;
- dùng máy trung gian để tiếp cận mạng khác (pivot);
- đánh giá lại;
- ghi chép.

Chuẩn bị cho thực tế khám phá, quyết định diễn ra theo chu kỳ.

Bài học chính

- Academy cân bằng chiều sâu kỹ thuật, hướng dẫn.

- Pentest cần nền tảng rộng nhiều lĩnh vực CNTT.
 - Lộ trình theo luồng pentest thật.
 - Làm quen quy trình lập, không tuyến tính.
-

Phần 3 — Academy Exercises & Questions

Dịch tiêu đề

Bài tập và câu hỏi Academy

Nội dung cốt lõi

Câu hỏi, lab không nhằm “bẫy” người học mà rèn suy luận cần ở thực tế. Nhiều nhiệm vụ lúc đầu mơ hồ, khó, thiếu rõ ràng một cách có chủ ý.

Thực tế:

- vấn đề hiếm khi được trình bày sẵn đầy đủ;
- không biết có bao nhiêu lỗi;
- không luôn rõ cần tìm gì;
- đặt đúng câu hỏi thường là phần lời giải.

Mục tiêu giảng dạy

- liên hệ lý thuyết, thực hành;
- đọc bối cảnh;
- tư duy phản biện;
- chịu đựng bất định;
- kiên trì.

Sai là phần quá trình, không phải bằng chứng thiếu năng lực.

Xin trợ giúp đúng

Không nên chỉ:

- “không giải được”;
- “cho đáp án”.

Cách trưởng thành:

- giải thích đã biết gì;
- mô tả đã thử gì;
- chỉ đúng chỗ mắc;
- xin xác minh hoặc định hướng.

Cải thiện học tập lẫn hình ảnh chuyên nghiệp.

Lời khuyên đội HTB

- kiên trì;
- tò mò;
- đơn giản;

- tiến bộ liên tục;
- ra khỏi vùng an toàn.

Bài học chính

- Độ khó phù hợp thuộc thiết kế HTB.
- Đặt câu hỏi tốt là kỹ năng nghề.
- Lời giải một phần có bối cảnh hơn xin đáp án sẵn.
- Tiến bộ thể hiện khi việc cũ dễ hơn sau ôn tập.

Phần 4 — Penetration [LAB_PASSWORD_REDACTED] Overview

Dịch tiêu đề

Tổng quan kiểm thử xâm nhập

Pentest là gì

Một nỗ lực tấn công:

- có tổ chức;
- có định hướng;
- được ủy quyền;
- đo mức dễ bị ảnh hưởng bởi lỗ hổng bảo mật.

Đánh giá tác động lên:

- tính bảo mật;
- tính toàn vẹn;
- tính sẵn sàng.

Tìm lỗ hổng, hỗ trợ cải thiện tư thế bảo mật.

Pentest so với đánh giá lỗ hổng

Đánh giá lỗ hổng

- tự động hơn;
- dựa trên quét;
- hướng lỗi đã biết;
- ít thích nghi bối cảnh hơn.

Pentest

- kết hợp tự động, xác minh thủ công;
- thích nghi mục tiêu;
- cần kế hoạch, phân tích, bối cảnh;
- kiểm thử tác động thực tế hơn.

Trong quản lý rủi ro

Pentester giúp:

- nhận diện;
- đánh giá;
- chứng minh tác động;
- định hướng giảm thiểu.

Pentest là **ảnh chụp tại một thời điểm** về an toàn, không giám sát liên tục.

Góc nhìn kiểm thử

Bên ngoài

- mô phỏng người tấn công Internet;
- tập trung vành đai;
- thường cần kín đáo hơn;
- tìm truy cập ban đầu từ biên.

Nội bộ

- bắt đầu trong mạng;
- giả định đã bị xâm nhập;
- hữu ích môi trường cách ly hoặc đánh giá sau xâm nhập.

Thông tin cung cấp

- **Blackbox**: tối thiểu.
- **Greybox**: một phần.
- **Whitebox**: tối đa.
- **Red Team**: theo mục tiêu/kịch bản.
- **Purple Team**: hợp tác phòng thủ.

Môi trường có thể kiểm thử

- mạng
- ứng dụng web
- di động
- API
- ứng dụng client cài trên máy (Thick Clients)
- IoT
- đám mây
- mã nguồn
- bảo mật vật lý
- nhân viên
- máy
- tường lửa
- IDS/IPS

Bài học chính

- Đánh giá được ủy quyền, có tổ chức, hướng tác động.
 - Khác đánh giá lỗ hổng ở chiều sâu, thích nghi.
 - Loại kiểm thử đổi phạm vi, thời gian, phương pháp, kín đáo.
 - Pentester ghi chép, chứng minh, khuyến nghị; không trực tiếp sửa môi trường.
-

Phần 5 — Laws and Regulations

Dịch tiêu đề

Luật và quy định

Nội dung cốt lõi

Tấn công thiếu nền tảng pháp lý, đạo đức gây rủi ro pháp lý nghiêm trọng. Mỗi nước/khu vực có luật về:

- truy cập trái phép;
- bản quyền;
- chặn bắt liên lạc;
- dữ liệu cá nhân;
- dữ liệu y tế;
- dữ liệu trẻ vị thành niên;
- chuyển dữ liệu;
- hạ tầng trọng yếu.

Ví dụ quy định được đề cập trong tài liệu gốc

Hoa Kỳ

- CFAA
- DMCA
- ECPA
- HIPAA
- COPPA

Châu Âu

- GDPR
- NIS/NIS2
- Cybercrime Convention — Công ước tội phạm mạng
- E-Privacy Directive — Chỉ thị quyền riêng tư điện tử

Vương quốc Anh

- Computer Misuse Act 1990
- Data Protection Act 2018
- Human Rights Act 1998
- Police and Justice Act 2006

- IPA 2016
- RIPA 2000

Ấn Độ

- Information Technology Act 2000
- Digital Personal Data Protection Act
- Indian Penal [LAB_CREDENTIAL_REDACTED] Evidence Act

Trung Quốc

- Cyber Security Law
- National Security Law
- Anti-Terrorism Law
- quy tắc chuyển dữ liệu quốc tế
- bảo vệ hạ tầng trọng yếu

Quy tắc thực tế

- lấy đồng ý bằng văn bản;
- tôn trọng phạm vi;
- giảm thiểu thiệt hại;
- không chặn bất liên lạc thiếu phép phù hợp;
- không thao tác/lưu dữ liệu cá nhân thiếu nhu cầu, ủy quyền;
- cản trở thêm với dữ liệu chịu quy định.

Bài học chính

- Ý tốt không thay ủy quyền chính thức.
- Phạm vi, đồng ý bảo vệ khách hàng và đơn vị tư vấn.
- Dữ liệu chịu quy định cần kiểm soát riêng.
- Hoạt động cần hợp pháp, tương xứng, ghi chép.

Phần 6 — Penetration [LAB_PASSWORD_REDACTED] Process

Dịch tiêu đề

Quy trình kiểm thử xâm nhập

Định nghĩa

HTB định nghĩa chuỗi bước, sự kiện pentester thực hiện để tìm đường tới mục tiêu định trước. Không phải công thức cố định; cần:

- linh hoạt;
- thích nghi;
- theo phát hiện;
- phụ thuộc bối cảnh khách hàng.

Bản chất

Mô-đun liên hệ quy trình **mang tính xác định**: mỗi phát hiện dẫn quyết định mới, quyết định mới tạo bằng chứng. Không phải hoàn toàn dự đoán được mà có quan hệ nhân quả giữa bước trước với hành động sau.

Giai đoạn chính

1. Trước dự án
2. Thu thông tin
3. Đánh giá lỗ hổng
4. Khai thác
5. Sau khai thác
6. Di chuyển ngang
7. Chứng minh khái niệm
8. Sau dự án

Tầm quan trọng việc lặp

Không làm theo checklist chung cho mọi nơi; thay vào đó:

- quay lại thu thông tin khi thiếu;
- đánh giá lại với bằng chứng mới;
- đổi đường nếu giả thuyết không xác nhận;
- ghi chép liên tục.

Bài học chính

- Quy trình, không tập lệnh cố định.
- Mỗi bước có lý do vận hành riêng.
- Luồng lặp, theo bằng chứng.
- Nắm quy trình cải thiện kế hoạch, thực thi, báo cáo.

Phần 7 — Pre-Engagement

Dịch tiêu đề

Giai đoạn trước dự án

Vai trò

Nền tảng pháp lý, vận hành, tổ chức. Khách hàng nói muốn kiểm thử gì; tư vấn giải thích thực hiện thế nào; hai bên định giới hạn chính thức.

Ba khối chính:

1. **Bảng câu hỏi xác định phạm vi**
2. **Họp trước dự án**
3. **Họp khởi động**

NDA trước tiên

Trước trao đổi nhạy cảm cần thỏa thuận bảo mật. Các loại:

- NDA đơn phương
- NDA song phương
- NDA đa phương

Song phương phổ biến nhất để bảo vệ phù hợp công việc.

Ai có thể đặt kiểm thử

Không phải nhân viên bất kỳ. Xác định người có thẩm quyền:

- đặt dịch vụ;
- ký hợp đồng;
- duyệt phạm vi;
- định Rules of Engagement;
- làm liên hệ chính, dự phòng.

Ví dụ CEO, CTO, CISO, CIO, CSO, CRO, kiểm toán nội bộ, quản lý cấp cao CNTT/bảo mật.

Tài liệu quan trọng

- NDA
- Scoping Questionnaire — câu hỏi phạm vi
- Scoping Document — tài liệu phạm vi
- Penetration [LAB_PASSWORD_REDACTED] [LAB_CREDENTIAL_REDACTED] / SoW — đề xuất, hợp đồng, bản mô tả công việc
- Rules of Engagement (RoE) — quy tắc thực hiện
- Contractors Agreement — thỏa thuận nhà thầu cho kiểm thử vật lý
- báo cáo

Tài liệu cần luật sư xem xét.

Bảng câu hỏi phạm vi

Để hiểu:

- loại đánh giá mong muốn;
- chiều sâu kỳ vọng;
- số tài sản;
- có cấp thông tin xác thực không;
- hộp đen/xám/trắng;
- mức né tránh phát hiện mong muốn;
- kỹ nghệ xã hội, không dây, vật lý, web, AD...

Ví dụ câu hỏi:

- số máy hoạt động dự kiến;
- số IP/CIDR trong phạm vi;
- số tên miền/tên miền con;
- số ứng dụng web/di động;

- có NAC không;
- cần đánh giá AD riêng không;
- không né tránh, kết hợp hay né tránh hoàn toàn.

Hợp trước dự án

Hai bên làm rõ thông tin, biến thành đề xuất chính thức, SoW.

Checklist hợp đồng và RoE

- mục tiêu;
- phạm vi;
- loại kiểm thử;
- phương pháp;
- địa điểm;
- khung giờ;
- bên thứ ba;
- rủi ro;
- giới hạn;
- xử lý thông tin;
- liên hệ;
- kênh trao đổi;
- định dạng báo cáo;
- thanh toán;
- cho phép kiểm thử.

Hợp khởi động

Thống nhất vận hành thực tế:

- kiểm thử diễn ra thế nào;
- người tham gia;
- khi nào dừng nếu phát hiện nghiêm trọng;
- báo sự cố thế nào;
- rủi ro khách chấp nhận;
- điều xảy ra nếu có tác động.

Thỏa thuận nhà thầu

Kiểm thử vật lý cần thỏa thuận bổ sung bảo vệ chính thức nếu đội bị kiểm tra khi hoạt động trực tiếp.

Bài học chính

- Trước dự án là phần trung tâm, có giá trị.
- Phạm vi tốt cải thiện chất lượng, thời hạn, giá, an toàn pháp lý.
- Hợp đồng/SoW, RoE biến trao đổi thành quy tắc.
- Khởi động thống nhất kỳ vọng, giảm nhiễu vận hành.

Phần 8 — Information Gathering

Dịch tiêu đề

Thu thập thông tin

Vai trò

Nền tảng mọi pentest. Khai thác, đánh giá phụ thuộc thông tin về:

- doanh nghiệp;
- nhân viên;
- hạ tầng;
- dịch vụ;
- máy;
- phòng thủ;
- dữ liệu nội bộ sau truy cập.

Bốn khối:

1. Tình báo nguồn mở (OSINT)
2. Liệt kê hạ tầng
3. Liệt kê dịch vụ
4. Liệt kê máy

OSINT

Dùng nguồn công khai tìm thông tin tổ chức, nhân viên. Có thể lộ:

- mật khẩu;
- hash;
- khóa SSH;
- token;
- chi tiết hạ tầng;
- mã/cấu hình nhà phát triển đăng.

GitHub, cả StackOverflow có thể lộ dữ liệu nhạy cảm mà tác giả không nhận ra.

Liệt kê hạ tầng

Lập bản đồ tổng thể:

- máy chủ tên;
- máy chủ thư;
- máy chủ web;
- máy đám mây;
- tài sản liên quan khác;
- quan hệ máy, vai trò mạng.

Tìm tường lửa, phòng thủ ảnh hưởng kín đáo và phát hiện.

Liệt kê dịch vụ

- dịch vụ lộ ra;
- phiên bản;
- lịch sử phiên bản;
- lý do tồn tại;
- thông tin cung cấp;
- hữu ích tấn công thế nào.

Liệt kê máy

Phân tích gần hơn:

- hệ điều hành;
- dịch vụ;
- phiên bản;
- cổng;
- vai trò mạng;
- quan hệ thành phần khác.

Góc nhìn nội bộ thường lộ nhiều hơn bên ngoài vì quản trị viên hay quá tin dịch vụ không trực tiếp ra Internet.

Pillaging

Thu thông tin nhạy cảm cục bộ sau xâm nhập. Không phải giai đoạn riêng, là hoạt động lặp trong sau khai thác, leo thang.

Bài học chính

- Thu thông tin quan trọng nhất, lặp nhiều nhất.
- OSINT có thể cho nhiều hơn dự kiến.
- Liệt kê hạ tầng, dịch vụ, máy tạo tầng hiểu biết.
- Pillaging là thu thông tin cục bộ sau xâm nhập.

Phần 9 — Vulnerability Assessment

Dịch tiêu đề

Đánh giá lỗ hổng

Vai trò

Quy trình **phân tích** dựa phát hiện thu thông tin. Không chỉ quan sát dữ liệu kỹ thuật mà diễn giải, giả thuyết, nghiên cứu, xác minh.

Bốn loại phân tích

Mô tả (Descriptive)

Mô tả tồn tại, tìm ngoại lệ/bất nhất.

Chẩn đoán (Diagnostic)

Giải thích nguyên nhân, kết quả, tương tác.

Dự đoán (Predictive)

Dùng lịch sử, hiện tại ước lượng điều có thể xảy ra/hướng khả dĩ.

Đề xuất (Prescriptive)

Quyết định kiểm thử gì, xác nhận, ưu tiên, giảm thiểu thế nào.

Thấy không đồng nghĩa có

Ví dụ **21/tcp** mở không tự xác nhận toàn bối cảnh dịch vụ. Cần hỏi:

- biết gì;
- chưa biết gì;
- thấy gì;
- thực có gì trong tay.

Tương tác mới để xác nhận hoặc bác dự đoán.

Nghiên cứu lỗ hổng

Liên hệ dịch vụ/phiên bản với:

- CVEdetails
- Exploit DB
- Vulners
- Packet Storm
- NIST

Phiên bản liên quan CVE tạo **giả thuyết mạnh**, không tự bảo đảm khai thác được.

Vai trò PoC

Thường cần:

- hiểu;
- điều chỉnh;
- thích nghi môi trường;
- đánh giá bối cảnh thật.

Đánh giá hướng tấn công khả thi

Nên tái tạo mục tiêu cục bộ khi có thể để xác minh, giảm bất định.

Quay lại thu thông tin

Nếu chưa đủ tin cậy, thu thêm bối cảnh. Pentest thật không phải CTF: chất lượng, chiều sâu hơn tốc độ.

Bài học chính

- Phân tích, không chỉ chạy trình quét.

- Cổng mở/phần bản là điểm đầu, không kết luận cuối.
- CVE liên quan là dấu hiệu mạnh, không sự thật tự động.
- Thu thông tin, đánh giá lỗ hổng hỗ trợ, phản hồi nhau.

Phần 10 — Exploitation

Dịch tiêu đề

Khai thác

Vai trò

Biến lỗ hổng phát hiện thành hành động. Không chỉ chạy mã mà **thích nghi điểm yếu với mục tiêu dự án**.

PoC có thể cần sửa đổi:

- phù hợp mục tiêu;
- tạo kết quả mong đợi;
- tôn trọng bối cảnh vận hành.

Ưu tiên tấn công

Ba yếu tố:

1. **Xác suất thành công**
2. **Độ phức tạp**
3. **Xác suất thiệt hại**

Hướng đơn giản, an toàn có thể tốt hơn hướng tinh vi, rủi ro, ít tin cậy.

Phức tạp, kinh nghiệm

Còn phụ thuộc mức thành thạo. Mã chưa từng dùng đòi nghiên cứu, lab, có nguy cơ lỗi cao hơn.

Khả năng thiệt hại

Hướng gây mất ổn định cần cực kỳ cẩn trọng. DoS chỉ thực hiện khi được cho phép rõ, có kế hoạch.

Chuẩn bị

- dựng mục tiêu cục bộ trong VM;
- chỉnh khai thác ở nơi an toàn;
- kiểm chứng kỹ thuật;
- ước lượng rủi ro trước môi trường khách.

Báo lên khi có nghi vấn, rủi ro

- báo khách;
- báo lãnh đạo/quản lý;
- lấy đồng ý dựa hiểu biết;
- hoặc ghi lỗ hổng chưa xác nhận chủ động khi phù hợp.

Sau khai thác

- giữ ghi chép rõ;
- cập nhật log hoạt động;
- thu bằng chứng;
- sang sau khai thác, di chuyển ngang.

Bài học chính

- Quyết định, thích nghi, không chỉ thực thi.
- Hướng tiên tiến nhất chưa chắc tốt nhất.
- Cân nhắc thành công, phức tạp, thiệt hại cùng nhau.
- Lab giảm rủi ro thực tế.

Phần 11 — Post-Exploitation

Dịch tiêu đề

Sau khai thác

Vai trò

Sau truy cập, công việc sâu hơn:

- hiểu hệ thống từ trong;
- lấy thông tin nhạy cảm liên quan bảo mật;
- giữ truy cập khi cần;
- nâng quyền;
- đánh giá tác động kinh doanh;
- chuẩn bị di chuyển ngang.

Thành phần:

- kiểm thử né tránh
- thu thông tin
- pillaging
- đánh giá lỗ hổng
- leo thang
- duy trì truy cập
- đưa dữ liệu ra ngoài

Kiểm thử né tránh sau truy cập

Lệnh đơn giản cũng có thể gây cảnh báo; EDR có thể theo dõi lệnh trình sát tường bình thường.

Cách tiếp cận:

- né tránh
- kết hợp né tránh
- không né tránh

Phụ thuộc phạm vi, mục tiêu.

Thu thông tin cục bộ

Khởi động lại từ góc nhìn mới:

- thư mục chia sẻ nội bộ;
- cơ sở dữ liệu;
- máy in;
- dịch vụ ảo hóa;
- quan hệ máy;
- nguồn thông tin xác thực, bối cảnh nội bộ.

Pillaging

Phân tích vai trò máy trên mạng:

- giao diện;
- định tuyến;
- DNS;
- ARP;
- dịch vụ;
- VPN;
- subnet;
- chia sẻ;
- lưu lượng.

Tìm:

- mật khẩu trong chia sẻ;
- script;
- cấu hình;
- kho mật khẩu;
- tài liệu;
- email.

Duy trì truy cập

Giữ quyền nếu mất kết nối, đặc biệt hướng ban đầu không ổn định/nhiều dấu vết.

Đánh giá lỗ hổng nội bộ

Lập đánh giá từ trong hệ thống, với quyền, cấu hình, bối cảnh thật.

Leo thang

Có thể:

- root Linux;
- SYSTEM, quản trị cục bộ/miền Windows;
- dùng thông tin xác thực tìm được để hoạt động với quyền cao hơn.

Đưa dữ liệu ra ngoài

Thường gặp dữ liệu nhạy cảm. Kiểm chứng cực cẩn trọng, ưu tiên dữ liệu giả khi có thể, thống nhất khách, xét:

- PCI
- HIPAA
- GLBA
- FISMA

Nhấn mạnh quay màn hình, ảnh chụp, bằng chứng nguồn và đường dữ liệu.

Bài học chính

- Biến truy cập thành bối cảnh, tác động.
- Thu thông tin, pillaging bắt đầu lại trong máy.
- Duy trì, leo thang, lấy dữ liệu cần phán đoán, lưu ý quy định.
- Bằng chứng tốt giúp chứng minh an toàn.

Phần 12 — Lateral Movement

Dịch tiêu đề

Di chuyển ngang

Vai trò

Xâm nhập từ đơn lẻ lan tới cấu trúc mạng. Không chỉ “vào máy” mà:

- truy cập dẫn tới đâu;
- quan hệ tin cậy;
- tài sản mới tiếp cận được;
- rủi ro hệ thống toàn tổ chức.

Ransomware minh họa lây nhiễm ban đầu lan toàn mạng.

Giai đoạn tái dùng

1. Pivoting
2. Kiểm thử né tránh
3. Thu thông tin
4. Đánh giá lỗ hổng
5. Khai thác (đặc quyền)
6. Sau khai thác

Thể hiện tính lặp.

[LAB_CREDENTIAL_REDACTED]

Dùng máy đã xâm nhập làm trung gian tới hệ thống/phần đoạn trước không tới được:

- mở rộng quan sát;
- mở rộng tầm tiếp cận;

- quét/hoạt động nội bộ trước bất khả tiếp cận.

Né tránh nội bộ

Mạng trong cũng có:

- phân đoạn nhỏ;
- giám sát đe dọa;
- IPS/IDS;
- EDR.

Thu thông tin, đánh giá nội bộ

Sau pivot/máy mới:

- lập bản đồ hệ thống;
- nhận diện tài nguyên;
- hiểu nhóm, quyền tài khoản bị xâm nhập;
- khai thác tin cậy.

Thông tin xác thực, định danh

Mật khẩu, hash, thành viên nhóm có thể nhân khả năng truy cập. Tài khoản có thể tới tài nguyên chia sẻ mở đường tiến sâu.

Sau khai thác trên từng máy mới

Mỗi máy mới có vòng sau khai thác, thu thông tin, phân tích, bằng chứng mới.

Bài học chính

- Đo phạm vi thực tế xâm nhập.
- Pivot biến máy thành cầu tới mạng nội bộ.
- Thông tin xác thực, nhóm, tin cậy là chìa khóa lan rộng.
- Máy mới khởi động lại một phần thu, đánh giá, đào sâu.

Phần 13 — Proof-of-Concept

Dịch tiêu đề

Chứng minh khái niệm

Vai trò

PoC chứng minh khả năng khai thác, giúp khách, nhà phát triển, quản trị:

- tái hiện;
- thấy tác động;
- thử khắc phục;
- quyết định theo bằng chứng.

PoC trong bảo mật

Chứng minh vấn đề thật sự tồn tại qua:

- tài liệu có cấu trúc;
- từng bước tái hiện;
- script;
- mã;
- trình diễn kỹ thuật có kiểm soát.

Nguy cơ sửa bề mặt

Chặn **script PoC** thay vì nguyên nhân gốc để lại vấn đề cấu trúc có thể khai thác đường khác.

Nguyên nhân so với triệu chứng

Ví dụ **[LAB_PASSWORD_REDACTED]**: lỗi không chỉ mật khẩu riêng mà chính sách yếu cho phép lựa chọn. Đổi một mật khẩu không sửa quản trị tạo điểm yếu.

Chuỗi tấn công

Trình bày kết hợp lỗi từ truy cập ban đầu tới xâm nhập rộng để khách:

- hiểu phát hiện phụ thuộc nhau;
- hiểu sửa một bước phá một đường, không nhất thiết mọi biến thể;
- ưu tiên theo tác động cấu trúc.

Bài học chính

- PoC phục vụ kỹ thuật, quản lý.
- Script chỉ là biểu hiện của lỗi.
- Tập trung nguyên nhân gốc, không chỉ chặn PoC cụ thể.
- Chuỗi tấn công truyền đạt tác động mạnh.

Phần 14 — Post-Engagement

Dịch tiêu đề

Sau dự án

Vai trò

Không kết thúc khi xong kỹ thuật. Cần:

- đóng an toàn;
- giao kết quả có thể hành động;
- hỗ trợ khắc phục;
- giữ tính toàn vẹn kiểm toán;
- kết thúc chuyên nghiệp.

Dọn dẹp

- xóa script, công cụ đã đưa lên;
- hoàn nguyên thay đổi nhỏ khi phù hợp;
- ghi mọi thay đổi;
- báo khách nếu không xóa được dấu vết/tệp.

Thay đổi đã hoàn nguyên cũng ghi báo cáo/phụ lục để đối chiếu cảnh báo.

Ghi chép, báo cáo

Trước ngắt kết nối, tổng hợp:

- đầu ra lệnh;
- ảnh chụp;
- máy ảnh hưởng;
- log;
- quét;
- bằng chứng cụ thể;
- bối cảnh tái hiện.

Báo cáo tốt gồm:

- chuỗi tấn công;
- tóm tắt điều hành tốt;
- phát hiện chi tiết, phân loại, tác động, tham chiếu;
- bước tái hiện rõ;
- khuyến nghị ngắn, trung, dài hạn;
- phụ lục kỹ thuật, phạm vi.

Nháp, xem xét, cuối

1. giao **báo cáo nháp**;
2. khách xem, góp ý;
3. **họp xem báo cáo**;
4. tích hợp phản hồi;
5. phát hành **báo cáo cuối**.

Kiểm thử sau khắc phục

Xác nhận đã sửa thật. Báo cáo sau so trạng thái trước/hiện tại, đánh dấu từng phát hiện đã/chưa khắc phục.

Vai trò pentester trong khắc phục

Giữ **bên thứ ba khách quan**. Có thể:

- định hướng tổng quát;
- giải thích;
- giúp tái hiện;
- hỗ trợ đội phụ trách.

Không nên:

- sửa mã;
- trực tiếp vá;
- đổi cấu hình khách;
- chịu trách nhiệm chính sửa lỗi.

Lưu giữ dữ liệu

- lưu an toàn, mã hóa dữ liệu khách;
- dọn dữ liệu/tệp trên hệ thống pentester;
- tạo VM mới riêng nếu cần điều tra sau;
- tuân hợp đồng, SoW, RoE, quy định.

Đóng dự án

- giao báo cáo cuối;
- giải đáp có giới hạn;
- kiểm thử lại nếu áp dụng;
- hủy an toàn/lưu kiểm soát tài liệu;
- hóa đơn, thanh toán;
- khảo sát hài lòng;
- suy ngẫm cải tiến quy trình, kỹ năng mềm.

Khách thường nhớ giao tiếp, chuyên nghiệp, cách đối xử hơn chuỗi khai thác tinh vi nhất.

Bài học chính

- Sau dự án thiết yếu cho giá trị pentest.
- Dọn dẹp đi cùng ghi chép.
- Báo cáo có thể hành động cho cả người kỹ thuật, không chuyên.
- Giữ độc lập với sửa lỗi.
- Kỹ năng mềm ảnh hưởng lớn trải nghiệm khách.

Phần 15 — Practice

Dịch tiêu đề

Thực hành

Thông điệp chính

Lý thuyết có giá trị khi thành thực hành thật. Ba trụ:

- lập có chủ đích;
- ghi chép nhất quán;
- phát triển kỹ năng chuyên môn, mềm cùng nhau.

Cần thực hành gì

Không chỉ:

- xâm nhập máy;
- giải thử thách;
- lặp lệnh.

Còn:

- viết email chuyên nghiệp;
- điều hành cuộc gọi khởi động;
- trình bày báo cáo;
- bảo vệ khuyến nghị trước khách;
- rèn làm việc nhóm.

Ghi chép thuộc thực hành

- củng cố kiến thức;
- tạo độ tin cậy;
- cải thiện trao đổi;
- chuẩn bị khách thật.

Kế hoạch gợi ý

- 2 mô-đun
- 3 máy đã nghỉ
- 5 máy đang hoạt động
- **1 Pro [LAB_CREDENTIAL_REDACTED]

Kế hoạch mô-đun

1. Đọc
2. Thực hành bài tập
3. Hoàn thành
4. Làm lại từ đầu
5. Ghi chú khi làm lại
6. Viết tài liệu kỹ thuật
7. Viết tài liệu không chuyên

Kế hoạch máy đã nghỉ

1. Lấy user flag
2. Lấy root flag
3. Tài liệu kỹ thuật
4. Tài liệu không chuyên
5. So lời giải chính thức/cộng đồng

6. Liệt kê điều bỏ sót
7. Xem lppSec
8. Bổ sung ghi chú

Kế hoạch máy đang hoạt động

1. Lấy user, root
2. Tài liệu kỹ thuật
3. Tài liệu không chuyên
4. Nhờ cả người kỹ thuật, không chuyên xem

Pro Labs, Endgames

Nhiều máy gần mạng doanh nghiệp thật hơn, rèn:

- chuỗi tấn công đầy đủ;
- chuyển giữa nhiều máy;
- tương tác thành phần mạng;
- ghi chép trường thành;
- nhìn xâm nhập cấu trúc thay máy riêng.

Kết thúc

- theo thứ tự lộ trình nếu mới;
- xem lại mô-đun qua góc nhìn quy trình;
- thực hành liên tục;
- phát triển phương pháp;
- học TTP cập nhật;
- không ngừng học.

Bài học chính

- Thực hành có chủ đích biến lý thuyết thành năng lực đáng tin.
- Ghi chép là kỹ năng kỹ thuật, không chỉ hành chính.
- Máy đã nghỉ giúp hiệu chỉnh; đang hoạt động giúp tự chủ; Pro Labs rèn chuỗi.
- Tiến bộ phụ thuộc học, làm, ôn, giao tiếp.

Tổng hợp cuối

Penetration [LAB_PASSWORD_REDACTED] Process là hướng dẫn tổng quát toàn lộ trình. Không dạy một hướng kỹ thuật riêng mà **cách nghĩ về công việc từ đầu tới cuối**.

Trụ cột:

1. Pháp lý, đạo đức
2. Phạm vi, hợp đồng, thống nhất
3. Thu thông tin là nền tảng
4. Phân tích lỗ hổng có phán đoán

5. Khai thác có ưu tiên, kiểm soát rủi ro
6. Sau khai thác cho bối cảnh, quyền, tác động
7. Di chuyển ngang đo tầm thực tế
8. PoC chứng minh, tái hiện, truyền đạt nguyên nhân
9. Sau dự án kết thúc chất lượng, khách quan
10. Luyện đều củng cố phương pháp, ghi chép, tự tin

Pentester tốt không chỉ khai thác mà:

- hiểu mục tiêu kinh doanh;
- tôn trọng phạm vi, rủi ro;
- thu, diễn giải sâu;
- quyết định có căn cứ;
- ghi rõ;
- giao tiếp tốt;
- giao giá trị thật.

Tóm tắt điều hành bài học quan trọng

- **Pentest không phải CTF.** Chất lượng, chiều sâu, trách nhiệm, sửa lỗi hơn tốc độ.
- **Quy trình quan trọng.** Thiếu luồng rõ làm công việc lộn xộn, rủi ro, khó bảo vệ về kỹ thuật.
- **Phạm vi, đồng ý không thể thương lượng bỏ qua.**
- **Thu thông tin là nền tảng thành công.**
- **Khai thác thiếu bối cảnh nguy hiểm.**
- **Sau khai thác, di chuyển ngang cho tác động thật.**
- **PoC truyền nguyên nhân, không chỉ script.**
- **Báo cáo, dọn, kiểm thử lại hoàn tất giá trị.**
- **Kỹ năng mềm, ghi chép định cách khách cảm nhận chất lượng.**
- **Thực hành có chủ đích, ôn liên tục giúp tiến bộ nghề.**

Ghi nhận hoàn thành

Trạng thái: Đã hoàn thành

Mô-đun: Penetration [LAB_PASSWORD_REDACTED] Process

Ngôn ngữ bản dịch: Tiếng Việt (gốc: Bồ Đào Nha Brazil)

Định dạng chính: Markdown cho GitHub

Sao lưu: PDF

Ghi công: Ghi chép gốc của Gabriel Martorelli — kho nguồn

([https://\[LAB_CREDENTIAL_REDACTED\]/hack-the-box-academy-notes](https://[LAB_CREDENTIAL_REDACTED]/hack-the-box-academy-notes)). Đây là bản dịch tiếng Việt, không phải tài liệu chính thức của Hack The Box Academy. Xem [ATTRIBUTION.md](#) ([ATTRIBUTION.md](#)) và [LICENSE](#) ([LICENSE](#)).